Data Protection, Confidentiality and Information Security Policy

Practice	Kirkcaldy Dental & Implant Clinic, 23–25 Tolbooth Street, Kirkcaldy KY1 1RW
PSM section	Ethical Practice › Data Protection (GDPR); Confidentiality and disclosure of information; Cyber security
Policy lead	Data Protection Lead [Name]
Version	1.0 (draft for adoption)
Adopted	[date]
Next review	[date – 12 months after adoption]

1. Purpose

This policy sets out how Kirkcaldy Dental & Implant Clinic collects, uses, stores, shares and disposes of personal information about patients, prospective patients, staff and others. It covers data protection law, patient confidentiality and the security of our IT systems. It also sets out what to do if something goes wrong: a data breach, a request for information, or a cyberattack.

2. Scope

This policy applies to:

- everyone who works at or for the practice: the Practice Owner, associates, hygienists, therapists, dental nurses, reception and management staff, trainees, locums, and contractors who may see personal data (IT support, cleaners, maintenance)
- all personal information we hold, in any form: electronic records, radiographs, photographs and scans, paper forms, letters, emails, text messages, phone calls, CCTV images (if installed – see Policy 15 – CCTV Policy), and conversations
- all systems we use, including:
  - **Dentally** (cloud patient management system – clinical records, appointments, medical histories, payments, recalls)
  - **Google Workspace** (practice email info@kirkcaldydental.co.uk, Google Drive, Sheets, Calendar)
  - **Meta (Facebook/Instagram) lead forms** used to collect waiting-list enquiries before opening
  - **ClickSend** SMS service used to text people on the waiting list
  - the NHS network (SWAN, via the NHS CAT20 router) and NHS.net email [when connected]
  - imaging software, intraoral scanners and implant planning software [list: name, supplier]
  - the practice website kirkcaldydental.co.uk and its contact forms
  - practice phones and any mobile devices.

3. Legislation and guidance

- Data Protection Act 2018 (DPA 2018)

- UK General Data Protection Regulation (UK GDPR)
- Data (Use and Access) Act 2025 (DUAA 2025) – in law since 19 June 2025. The PSM data protection pages are under review because of this Act; check the ICO website and PSM news for changes before adopting and at each review.
- Age of Legal Capacity (Scotland) Act 1991
- The National Health Service (General Dental Services) (Scotland) Regulations 2010, Schedule 1 (Terms of Service), Part IV paragraph 27 (records)
- Privacy and Electronic Communications Regulations (for marketing texts and emails) – check current ICO guidance
- GDC Standards for the Dental Team, Principle 4: Maintain and protect patients' information
- NHS Scotland – Protecting Patients' Confidentiality: Code of Practice (2023)
- Records Management Code of Practice for Health and Social Care (2024)
- National Cyber Security Centre (NCSC) – Small Business Guide: Cyber Security; Cloud Security Guidance; Phishing attacks guidance; Response and Recovery guide
- Information Commissioner's Office (ICO) – UK GDPR guidance and resources

PSM pages:

- https://www.psm.sdcep.org.uk/topics/ethical-practice/data-protection/
- https://www.psm.sdcep.org.uk/topics/ethical-practice/data-protection/general-data-protection-regulations-gdpr/ (and sub-pages: data processing, data protection fee, data protection policy, awareness, information held, privacy notice, data sharing, individual rights, subject access requests, lawful basis, consent, children, data breaches, data protection by design and default, data protection impact assessments, data protection officer, international transfer of data)
- https://www.psm.sdcep.org.uk/topics/ethical-practice/confidentiality-and-disclosure-of-information/ (and sub-pages)
- https://www.psm.sdcep.org.uk/topics/ethical-practice/cyber-security/ (and sub-pages: data backups, passwords, mobile devices, malware, phishing, procedures for dealing with a cyberattack)
- https://www.psm.sdcep.org.uk/topics/record-keeping/storage-of-records/

4. Responsibilities

Data controller – [Kirkcaldy Dental & Implant Clinic Ltd / Nas Abrar trading as Kirkcaldy Dental & Implant Clinic – confirm legal entity]. The controller decides why and how personal data is processed and is legally accountable.

Practice Owner [Nas] – overall responsibility for data protection and confidentiality; pays the ICO fee; signs data processing agreements; makes final decisions on disclosures to police and other third parties.

Data Protection Lead [Name] – day-to-day lead for this policy: keeps the information audit, privacy notices and logs up to date; handles subject access and other rights requests; first point of contact for data breaches; organises training.

Data Protection Officer (DPO) [Name / external provider] – see section 5.4. Because the practice provides NHS services, it is a public authority for data protection purposes and **must appoint a DPO**.

Practice Manager [Name] – IT administration and access control (with the IT support company), backups, staff starters and leavers, contracts with suppliers.

IT support company [Company, contact, phone] – security configuration, patching, antivirus, firewall, incident response.

All staff – keep information confidential, follow this policy, complete training, and report any breach or suspected breach immediately.

5. Policy and procedure

5.1 Key terms

- **Personal data** – information about a living person who can be identified from it, alone or with other information (for example name, address, email, online profile, staff HR record).
- **Special category data** – sensitive data including health information (all clinical records and medical histories) and ethnic origin. All information obtained in caring for patients is confidential.
- **Processing** – anything done with personal data: collecting, entering into Dentally, storing, viewing, sharing, deleting.
- **Data processor** – an organisation that processes data on our behalf (for example Dentally, Google, ClickSend, the IT company, payroll provider). Controllers must make sure their processors comply; both have legal liability for breaches.

5.2 Data protection principles

Personal information must be:

1. processed fairly, lawfully and transparently
2. collected for specified, lawful purposes and not used for anything incompatible (purpose limitation)
3. adequate, relevant and not excessive (data minimisation)
4. accurate and up to date
5. not kept longer than necessary (storage limitation)
6. kept secure – integrity and confidentiality (for example password protection, restricted access, locked cabinets)
7. and we must be able to show that we comply (accountability).

Data protection by design and default is a legal requirement. Whenever we set up or change a process that uses personal data (a new form, new software, a new marketing campaign), we build in data protection from the start: collect only what we need, restrict access to those who need it, and delete when no longer required. Examples: the medical history form asks only for relevant social history; only clinical staff open clinical notes; waiting-list data is deleted when no longer needed.

5.3 ICO registration (data protection fee)

1. The practice is a data controller and must pay the annual data protection fee to the ICO **before processing starts** (the waiting list already counts as processing). Use the ICO fee self-assessment tool to work out the tier (it depends on staff numbers and turnover).
2. ICO registration number: [number]. Renewal date: [date]. The Practice Manager diarises renewal.
3. Tell the ICO about any change (address, contact details, trading name). A change of legal status (for example sole trader to limited company) needs a new registration.
4. Self-employed associates, hygienists or therapists may need to pay their own fee if they are data controllers – for example if they hold a patient list that would follow them, treat the same patients at different practices, or would be legally responsible if a complaint was made or data lost. Each self-employed clinician confirms their position in writing and gives us their ICO number if they have one. Employed staff, VDPs and employed assistants do not pay a fee.

5. Failure to register or renew can lead to prosecution, a fine and a complaint to the GDC.

5.4 Data Protection Officer

1. The practice appoints a DPO: [Name / external DPO service – company, contact]. [Practice decision: internal or external.]
2. The DPO must be independent, expert in data protection, adequately resourced, and report to the Practice Owner. The DPO **should not be the person with overall responsibility for processing** (so not the Practice Owner). If an employee such as the Practice Manager is appointed, they must receive DPO training, be able to act independently, and have no conflict of interest. Alternatively, use an external provider or share a DPO with other local practices.
3. The DPO's duties: inform and advise staff; monitor compliance with this policy, including internal audits and training; advise on DPIAs; co-operate with the ICO; and be the contact point for the ICO, patients and staff.
4. DPO contact details (they need not include a name) are published in the privacy notices and on the website, and given to the ICO. The DPO's name is given when reporting a breach to the ICO and to affected individuals.
5. If the practice does not follow the DPO's advice, the reasons are documented.

DPO contact: [dpo email, e.g. dpo@kirkcaldydental.co.uk or provider's address], [phone].

5.5 Information audit – what we hold

The Data Protection Lead keeps an information audit (use the PSM GDPR Information Audit template) and reviews it yearly and whenever a new system or process is introduced. It records, for each type of data: what we hold; why; how and where it was collected; the lawful basis; who can access it; how it is secured; who it is shared with; how long it is kept; and how it is destroyed.

Starting list (to be completed):

Data	System	Lawful basis (and special category condition)	Retention
Patient clinical records, radiographs, photos, scans, medical histories	Dentally; imaging software [name]	Public task (NHS care) / contract (private care); special category: provision of health care	10 years from last contact (adults and children); see 5.12
Appointments, recalls, reminders	Dentally (SMS/email reminders)	Legitimate interests / public task (recall and reminders for care)	As for records
Payments and NHS claims	Dentally; NHS claims (PSD); accounts	Legal obligation (tax, NHS); contract	[6 years for financial records – check with accountant]
Waiting-list enquiries (name, phone, email, interest, sometimes treatment interest)	Meta lead forms → [Google Sheet / Dentally]; ClickSend	Consent (opt-in)	Until the person registers, asks to be removed, or [6 months after opening], whichever is first
Marketing (newsletters, offers)	[ClickSend / email tool]	Consent – separate opt-in	Until consent withdrawn
Website enquiries	Google Workspace email	Legitimate interests / steps before a contract	[12 months] unless they become a patient

Data	System	Lawful basis (and special category condition)	Retention
Staff HR, payroll, contracts, GDC, indemnity, PVG, immunisation, training	Google Drive (restricted folder); payroll provider [name]	Contract; legal obligation; special category: employment / occupational health	[6 years after employment ends – check current guidance]
Complaints	Complaints log (restricted)	Legal obligation (NHS complaints)	[check Policy 01 – Feedback, Comments, Concerns and Complaints Procedure]
CCTV (if installed)	[system]	Legitimate interests	See Policy 15 – CCTV Policy

5.6 Lawful basis

1. We identify and record a lawful basis for every purpose (above) and state it in our privacy notices. For health data we also record the special category condition.
2. The PSM lists seven lawful bases: consent; contract; legal obligation; vital interests; public task; legitimate interests; and recognised legitimate interests (added by the DUAA 2025). In dentistry the bases most likely to apply are contract or legal obligation (treatment, essential employee information), legitimate interests (recalls and appointment reminders – we must justify these), and consent (marketing such as newsletters and special offers).
3. [Practice decision, confirm with DPO: NHS care – "public task"; private care – "contract"; special category condition – "health or social care" in both cases.]
4. **Consent for treatment is not the same as data protection consent.** Patient records are held under a duty of confidence and implied consent for direct care. Data protection consent is not the lawful basis for patient or staff records.
5. Where we rely on **data protection consent** (waiting list, marketing):
   - the request is prominent, concise, separate from other terms, and names the practice and any third parties relying on it (for example Meta, ClickSend)
   - people actively opt in – no pre-ticked boxes or default settings
   - there are separate (granular) options for different purposes (for example "Contact me about opening and booking" and, separately, "Send me offers and news")
   - we keep a record of who consented, when, how, and what they were told
   - withdrawing is easy (for example "Reply STOP" in every marketing SMS, and an unsubscribe link in emails)
   - children under 13 cannot give their own data protection consent; a person with parental responsibility must consent.

5.7 Waiting list, Meta lead forms and ClickSend SMS

This applies to people who have registered interest before the practice opens.

1. **Meta lead forms** must show a privacy statement linking to our privacy notice, state what we will use the details for, and have unticked opt-in boxes for (a) contact about opening and registering and (b) marketing, if used. Do not ask for health information on lead forms beyond a broad treatment interest. [Check the form wording before each campaign.]

2. Leads are downloaded from Meta to [a restricted Google Sheet in the practice Google Workspace / imported into Dentally] at least [weekly], and then deleted from Meta Leads Center / downloaded CSVs on staff devices are deleted. Access is limited to [Practice Manager, reception].
3. **ClickSend**: only numbers with a recorded opt-in are uploaded. Every marketing message identifies the practice and includes an opt-out (for example "Reply STOP to opt out"). Opt-outs are actioned within [2 working days] in ClickSend and the master list. ClickSend account access uses two-factor authentication.
4. When a waiting-list contact registers as a patient, their data moves into Dentally under the patient privacy notice and is removed from the waiting list. Waiting-list data is deleted at the retention date in 5.5.
5. **Data processing terms**: before use, the Practice Manager confirms and files the data processing terms (DPA) for Meta (lead ads terms), ClickSend, Google Workspace and Dentally, and records where each stores data (see 5.10).
6. Do not upload patient or waiting-list lists to Meta for "custom audiences" unless the DPO has advised it is lawful and the privacy notice says so. [Practice decision.]

5.8 Privacy notices

1. We give privacy information **before** we start processing. The practice has three privacy notices (see Policy 11 – Privacy Notices – Patients, Children and Staff): patients; children (age-appropriate); staff. Waiting-list contacts are covered by the patient privacy notice [or a short waiting-list notice].
2. The patient notice is on the website, displayed in the waiting room, and given in print to new patients. The staff notice is discussed at a practice meeting and given at induction.
3. Notices are reviewed at least yearly and whenever processing changes.

5.9 Data sharing and processors

1. Before sharing personal data with an external processor (for example dental laboratories, implant suppliers, payroll, IT support, software suppliers, the SMS provider, an external DPO, confidential waste contractor), we have a written agreement that covers: what data is shared; how the processor will use it; how they store it securely and for how long; and how they dispose of it. Processors must report any breach to us as soon as they become aware – we then have the duty to report to the ICO within 72 hours.
2. Use a secure route:
   - **Email**: use NHS.net email for clinical information within the NHS [once the practice has NHS.net accounts]; outside the NHS, only send personal data by encrypted email [Google Workspace: confirm method, e.g. Gmail confidential mode is not encryption – use client-side encryption or a password-protected file with the password sent separately].
   - **Post**: recorded delivery for records.
   - **High volumes** of sensitive data: the NHS Scotland SWAN Secure File Transfer Service.
3. Share only the minimum information necessary, on a need-to-know basis.
4. If we find we have shared incorrect information, tell the recipient and what needs to be done to correct it.
5. Keep a data processors register: supplier, purpose, data, agreement date, data location, review date.

5.10 International transfers

1. Personal data must not be transferred outside the UK unless appropriate safeguards are in place (or the country has UK "adequacy").

2. The Practice Manager confirms in writing, for each supplier, whether data is sent or stored outside the UK, and records the safeguard:
   - Dentally – [confirm hosting location]
   - Google Workspace – [confirm data region settings and the UK transfer safeguards in Google's terms]
   - Meta lead forms – [Meta processes data in the US and elsewhere; record the safeguard]
   - ClickSend – [confirm where message data is stored and the safeguard]
   - Implant planning software and overseas laboratories or suppliers – [list]
3. Where data is stored outside the UK, additional measures are needed. Ask the indemnity provider or DPO for advice, especially before sharing identifiable data with laboratories or suppliers outside the UK.

5.11 Confidentiality

1. All personal health information is confidential: notes, radiographs, photographs, treatment details, appointment records, payments, and any other personal information (for example medical conditions).
2. Every staff contract and contractor agreement contains a confidentiality clause. A breach of confidentiality is serious and can lead to disciplinary action, including dismissal.
3. Respect privacy at reception: do not discuss medical history, payments, or proof of NHS exemption where others can hear. Offer a private room. Do not read out full names and treatment details on the phone in the waiting area. Screens face away from the public.
4. Do not discuss patients outside the practice, including on social media or in personal messaging apps. Do not take photos of patients or records on personal phones.
5. Patients are told at registration, through the privacy notice, how their information is normally shared. **Specific consent is not needed** each time for normal healthcare sharing with people who "need to know", for example:
   - referral to other dental care providers or hospital services
   - discussions with the patient's doctor
   - information sent to dental laboratories.
6. Disclosure to Practitioner Services Division (PSD), NHS Fife and Dental Reference Officers is required for the NHS system to work. Dentists must provide relevant information to them **within 14 days of a request** (GDS Regulations 2010, Schedule 1, Part IV, paragraph 27).
7. If sharing is **out of the norm** and not described in the privacy notice, get the patient's specific consent (use the PSM Consent Form template) and record it.
8. If a patient asks for information to be withheld from someone, explain the consequences for their care, but the patient makes the final decision. Record the discussion.
9. Family members, carers and other third parties: only share information with the patient's consent, or where another lawful route applies (for example a welfare attorney or guardian with the relevant power, or a parent of a child who lacks capacity).

5.12 Disclosure to prevent serious crime or harm

1. Exceptional circumstances can override the duty of confidence: a serious public health risk, a risk of harm to others, or information required by the police for crime or taxation purposes. The DPA 2018 exemption only allows release for the stated purpose and, for crime, only if not releasing it would be likely to significantly harm police attempts to prevent crime or catch a suspect.

2. A data controller is under no obligation to disclose to a third party unless there is a statutory obligation or a court order. It may be necessary to ask the police for a court order.
3. Procedure:
    1. Ask for the request in writing, signed by someone of sufficient authority. A verbal request is acceptable only if there is an immediate risk to life or public safety; it must be followed up in writing.
    2. Check the requester's identity (for example check the warrant card and call the station back on a known number).
    3. The decision is made by the Practice Owner (or the senior dentist present), who must be able to defend it.
    4. Consider the seriousness of the crime, the risk to the public and the reason for the request.
    5. Examples where disclosure to police may be appropriate: helping identify a body (the police must have a body); an offence under the Road Traffic Act 1988; matters under the Terrorism Prevention and Investigation Measures Act 2011; a patient evading NHS charges (fraud), when directed by the authorities.
    6. Disclose only what is necessary.
    7. Routine HMRC tax enquiries: without a court order, anonymise appointment books and records before providing them.
    8. Record every disclosure in the **disclosure register** (date, requester, authority, information disclosed, reason, decision maker).
    9. If in doubt, contact the indemnity provider [name, phone] before acting.
4. Child and adult protection concerns: see Policy 12 – Child and Adult Protection (Safeguarding) Policy. There is no data protection barrier to reporting suspected abuse.

5.13 Individual rights

People have the right to: be informed; access; rectification; erasure; restrict processing; data portability; object; and not be subject to automated decision-making, including profiling. All requests are passed to the Data Protection Lead and logged in the **rights requests log**.

Request	What we do	Time limit
Rectification	Check and correct inaccuracies. Clinical records are not altered: if a diagnosis was wrong, the original entry stays and a dated note is added giving the correction.	Within one month
Erasure or restriction	Comply without undue delay unless exempt. We do not delete dental records or essential employee records we must keep for legal and professional reasons; explain this to the person. Waiting-list and marketing data are deleted on request.	Within one month
Portability / records to another practice	Send electronic records in a structured, commonly used, machine-readable format (for example PDF) by	Within one month

Request	What we do	Time limit
	a secure route. Keep our copy for the retention period.	
Objection (for example to marketing)	Stop marketing immediately.	Without delay

When we receive records from a previous dentist, we also must handle them in line with data protection law.

5.14 Subject access requests (SARs)

1. Anyone can ask for a copy of their personal data. A request **need not be in writing**. Verbal requests are handled the same way: reception writes it down in the SAR log straight away and tells the Data Protection Lead.
2. **Time limit**: respond as soon as possible and within **one calendar month** of receipt.
   - If the request is unclear, ask for clarification. Under the DUAA 2025 the clock stops on the day clarification is requested and restarts when it is received.
   - The deadline can be extended by up to **two further months** if the request is complex or the person has made several requests. Tell them within the first month and explain why.
3. **Identity**: check the requester's identity before releasing anything. Third parties (for example a solicitor, or a parent) must show they are entitled to act, such as the patient's signed consent.
4. **Children**: in Scotland a child aged **12 or over** is presumed to have sufficient age and maturity to exercise their own right of access unless shown otherwise; the dentist assesses capacity and maturity. A person with parental responsibility may request the child's information if the child authorises it, if the child lacks understanding, or if it is in the child's best interests.
5. **Search**: use a reasonable and proportionate search (Dentally, imaging software, email, Google Drive, paper), focused on what was asked for (for example a treatment or date range).
6. **Fee**: free of charge, in a commonly used electronic format. A reasonable fee can be charged only for manifestly unfounded or excessive requests or for further copies.
7. **Explain** the record where needed (for example dental abbreviations and charting). State the lawful basis for processing in the response.
8. **Refusal** (rare): only if manifestly unfounded or excessive. The criteria are: [practice to define, with DPO advice]. Tell the requester within one month why, and that they can complain to the ICO and seek legal advice. Consider advice from the indemnity provider or ICO first.
9. Send the response securely and record what was sent and when.

5.15 Personal data breaches

A personal data breach is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. Examples: an email with a patient's details sent to the wrong person; a lost phone or laptop; a waiting-list spreadsheet shared publicly; Dentally accessed by someone who should not; ransomware.

Procedure:

1. **Report immediately** to the Data Protection Lead (or the Practice Owner if unavailable). Do not try to hide it. Staff will not be blamed for reporting honestly.
2. **Contain** it: recall or ask the recipient to delete an email, change passwords, remotely wipe a lost device, remove a public link.

3. **Assess** the risk to people's rights and freedoms (discrimination, damage to reputation, financial loss, loss of confidentiality, other significant disadvantage). A breach of patient confidentiality is likely to be notifiable.
4. **Report to the ICO within 72 hours** of becoming aware, if the breach is likely to result in a risk to individuals. Include the DPO's name and contact. If all the facts are not yet known, report what is known and follow up. It may help to talk to the indemnity provider first, but do not miss the 72-hour deadline.
5. **Tell the individuals** without undue delay if the breach is likely to result in a high risk to them (for example identity theft or breach of confidentiality).
6. If a processor (for example Dentally, Google, ClickSend) has a breach, they must tell us as soon as they are aware; we then report to the ICO within 72 hours.
7. **NHS breaches**: also inform NHS Fife Information Governance (fife.dataprotection@nhs.scot; switchboard 01592 643355) where NHS systems or NHS patient data are involved.
8. **Record every breach**, including those not reported to the ICO, in the breach log: what happened, data and people affected, actions, whether reported and why or why not, and lessons learned. Discuss at a practice meeting and treat it as a significant event (see Policy 37 – Risk Management and Significant Events Policy).

Failure to report a notifiable breach can lead to a fine, in addition to a fine for the breach itself.

5.16 Data protection impact assessments (DPIAs)

A DPIA is mandatory where processing is likely to result in high risk to individuals, for example new technology. In dentistry this is likely when introducing a new software package or installing CCTV. [Practice decision: the DPO should advise whether a DPIA is needed for Dentally, the Meta/ClickSend waiting list, AI tools or any new implant planning software.]

If a DPIA is required:

1. describe the processing
2. identify and assess the risks to individuals
3. identify how the risks will be reduced
4. record the outcome, and the DPO's advice.

5.17 Children's data

Children's data is protected in the same way as adults'. Systems must let us check the age of child patients (date of birth in Dentally). The children's privacy notice explains their rights in plain language. If data protection consent is ever used for a child (for example a competition or marketing – [practice decision: we do not market to children]), only children aged 13 or over can consent for themselves; for under-13s we need consent from a person with parental responsibility. Where a parent consented, the child can withdraw that consent once competent, and erasure must be as easy as the original sign-up.

5.18 Storage, retention and disposal

1. **Retention** (PSM, Record-keeping): adult and child records are kept for **10 years from last contact**; the child record evolves into the adult record. On death, adult records are kept for **3 years**. Where a person dies before their 17th birthday, the record is held until they would have turned 25. See Policy 36 – Clinical Record-keeping and Retention Policy. Other retention periods are set in the information audit.
2. Do not keep records longer than necessary. The Data Protection Lead runs a [yearly] retention review and deletion.

3. **Paper**: kept in lockable, fire-proof cabinets, locked when unattended. Disposed of by shredding or incineration, preferably by a confidential waste company that gives a certificate of destruction [contractor].
4. **Electronic**: deleting files or reformatting is not enough. Old computers, phones, USB drives and scanner hard drives are securely wiped or destroyed by [IT company / certified contractor], with a certificate.
5. Windows and doors are secured at the end of each day.

5.19 Accuracy

Patients' contact details and medical histories are checked at each appointment. Staff and associate details are checked yearly.

5.20 Cyber security

General

1. The practice follows the NCSC Small Business Guide. If we are not confident setting up or managing IT security, we take advice from a qualified provider: [IT support company].
2. When connected to the NHS network, the practice complies with the terms of service and acceptable use policy for the SWAN connection (via the NHS CAT20 router).
3. NHS Fife guidance on cyber security and ransomware is followed in the first instance.

Passwords and access

1. Every user has their own login for every system (Dentally, Google Workspace, imaging, ClickSend, Meta Business). Logins are never shared.
2. Use strong, non-predictable passwords (for example three random words). Use the practice password manager [name] where provided. Do not write passwords down.
3. Two-factor authentication is switched on for Google Workspace, Dentally, Meta Business, ClickSend, online banking and any other service that offers it.
4. Password protection and built-in encryption (for example BitLocker or FileVault) are switched on for all computers and laptops.
5. Computers lock automatically after [5] minutes. Staff lock their screen (Windows key + L) whenever they leave it.
6. Users only have access to the systems and data needed for their role. Standard accounts cannot install software or change security settings. Administrator accounts are given only to those who need them and are used only for IT administration.
7. All default passwords on new equipment (routers, scanners, CCTV, cameras) are changed before use.
8. **Leavers**: on the last day the Practice Manager removes access to all systems, recovers devices and keys, and changes any shared codes (alarm, door).

Malware

1. Antivirus software is installed and kept up to date on all computers; the firewall is switched on.
2. All software, firmware and operating systems are updated promptly, with automatic updates on where possible. Software that is no longer supported is replaced.
3. USB drives and memory cards are [blocked / only practice-approved drives allowed]. Transfer files by secure email or cloud storage instead.
4. Staff delete suspicious emails and are wary of unexpected attachments and links.

5. Personal email and personal internet use on practice computers is [not permitted / limited to break times].

Phishing

1. Email filtering is enabled in Google Workspace to send phishing to spam (it is not foolproof).
2. Signs of phishing: unexpected invoices; requests for passwords, bank details or urgent payments; poor spelling, grammar or logos; links to login pages. Banks will not ask for login details by phone or email.
3. Any request to change a supplier's bank details, or to make an urgent payment, is checked by phoning the supplier on a known number.
4. Report suspicious emails to the Practice Manager. Do not forward to colleagues. If you clicked a link or entered a password, report it immediately – we will not blame you.
5. If a successful attack is suspected: scan for malware and change passwords as soon as possible.
6. Set up DMARC (with SPF and DKIM) for kirkcaldydental.co.uk to stop criminals spoofing our email address [IT company / web developer to action].
7. Keep the website and social media to essential details about the practice and staff (our "digital footprint").
8. Online fraud, scams or extortion: report to Police Scotland on 101.

Mobile devices

1. Any phone or tablet used for practice work (including Dentally, email, Meta or ClickSend apps) has a strong PIN or password and fingerprint or face recognition switched on.
2. Track, lock and remote-wipe are switched on [mobile device management: name, if used].
3. Operating systems and apps are kept up to date; devices past their supported life are replaced.
4. Apps are installed only from Google Play or the Apple App Store.
5. Do not use unknown or public Wi-Fi for practice work; use the mobile network or a mobile dongle.
6. Personal devices: [Practice decision – permitted only for Google Workspace and Dentally with 2FA and screen lock, no downloading of patient data / not permitted]. Staff must not store patient photos or records on personal devices.
7. Report a lost or stolen device immediately (it may be a data breach – see 5.15).

Backups

1. Critical data: patient records (including radiographs and photographs), financial information, documents, emails, contacts and appointment calendars.
2. Dentally is cloud-hosted and backed up by the supplier. The Practice Manager confirms in writing Dentally's backup arrangements and how quickly data can be restored [record here].
3. Data held locally (imaging software, intraoral scans, implant planning files, any local files) is backed up automatically [daily] to [cloud service / separate device], stored separately from the main systems and not permanently connected (so ransomware cannot reach it). Google Drive data is covered by [backup arrangement].
4. Access to backups is restricted to authorised people.
5. A test restore is done [every 6 months] and recorded.
6. The backup protocol is written down and included in the business continuity plan (Policy 38 – Business Continuity Plan).

5.21 Procedure if a cyberattack is suspected

1. **Do not pay any ransom.**
2. Disconnect the affected device from the network (unplug the cable / turn off Wi-Fi). Do not switch it off unless told to by IT support.
3. **Within 30 minutes of discovery (ideally):**
   - Contact **Practitioner Services Division (PSD)** on 0345 034 2458 (nss.psddental@nhs.scot) to report it and have the CAT20/SWAN connection cut to protect the NHS network. If NSS cannot disable it remotely straight away, unplug the SWAN router.
   - Phone the **NHS Fife Information Governance Lead** (fife.dataprotection@nhs.scot; switchboard 01592 643355) immediately. (If the owner has practices in other Board areas, tell them too.)
   - Phone the **IT support company** [phone] to report the attack and arrange cleansing of the systems.
4. Contact **Dentally** support [phone/email] (and other software suppliers) to report the attack and discuss recovering data once the system is clean.
5. Report to **Police Scotland** (101) if applicable.
6. Report to the **ICO within 72 hours** of discovering a personal data breach, if applicable (see 5.15).
7. Change passwords; check Google Workspace and Meta account activity for unknown logins.
8. Follow the business continuity plan to keep seeing patients where safe.
9. Record it as a data breach and significant event and review lessons learned.

Keep a printed copy of these contacts at reception and off-site.

6. Records and monitoring

Record	Where	Review
ICO registration certificate and renewal date	Compliance folder	Yearly
DPO appointment letter / contract	Compliance folder	Yearly
Information audit (record of processing)	Google Drive – Data Protection (restricted)	Yearly and on change
Data processors register and agreements (Dentally, Google, Meta, ClickSend, IT, payroll, labs, waste)	As above	Yearly
International transfer checks	As above	Yearly
Consent records for waiting list and marketing	Lead form export / ClickSend / Dentally	Ongoing; purge at retention date
SAR and rights requests log	As above	Each request; reviewed quarterly
Breach log	As above	Each incident; reviewed quarterly
Disclosure register	As above	Each disclosure
DPIAs	As above	When processing changes
IT access list (who has which accounts and admin rights)	Practice Manager	Quarterly and at each starter/leaver

Record	Where	Review
Backup test log; patching and antivirus checks	IT log	[6-monthly / monthly]
Staff training records	Staff files	Yearly

The DPO carries out a data protection audit [yearly] and reports to the Practice Owner. Results are minuted at a practice meeting. The practice's risk management processes are reviewed and the outcome recorded.

7. Training

- All staff complete data protection, confidentiality and cyber security training at induction (before accessing Dentally) and yearly. Training covers this policy, confidentiality, recognising and reporting breaches, SARs, phishing and password practice.
- [Training provider/course, for example NES TURAS information governance or indemnity provider module.]
- The internal DPO (if appointed) completes DPO training.
- Staff sign this policy and the confidentiality clause in their contract.
- GDC registrants are recommended to include legal and ethical issues, including data protection, in their CPD.

8. Related policies and templates

PSM templates to download and adapt (https://www.psm.sdcep.org.uk/topics/ethical-practice/):

- Data Protection, Confidentiality and Information Security Policy template (Dec 2024)
- GDPR Privacy Notice for Patients template (Dec 2024); GDPR Privacy Notice for Staff template; GDPR Privacy Notice for Children template
- GDPR Information Audit template
- Consent Form template (for sharing information)
- Ethical Practice checklist

Related policies in this set:

- Policy 11 – Privacy Notices – Patients, Children and Staff
- Policy 12 – Child and Adult Protection (Safeguarding) Policy
- Policy 14 – Freedom of Information Policy and Publication Scheme
- Policy 15 – CCTV Policy
- Policy 03 – Consent Policy
- Policy 06 – Referrals and Communication with Other Professionals Protocol
- Policy 08 – Practice Information and Advertising Policy
- Policy 36 – Clinical Record-keeping and Retention Policy
- Policy 37 – Risk Management and Significant Events Policy
- Policy 38 – Business Continuity Plan
- Policy 22 – Waste Management Policy (confidential waste)

9. Inspection checklist

- ☐ ICO data protection fee paid and in date (certificate available)
- ☐ DPO appointed; contact details published in privacy notice and given to the ICO
- ☐ Data protection, confidentiality and information security policy in place and signed by staff
- ☐ Patient privacy notice on website, displayed in waiting room and given to new patients; children's and staff notices in place
- ☐ Information audit completed with lawful bases recorded
- ☐ Data processing agreements with suppliers; international transfers checked
- ☐ Confidentiality clause in all staff contracts
- ☐ SAR procedure (one month) and log; breach procedure (72 hours) and log; disclosure register
- ☐ Records stored securely; screens locked; individual logins; antivirus, firewall and updates in place
- ☐ Backup protocol documented and tested; backups held separately
- ☐ Cyberattack procedure with PSD, NHS Fife and IT contacts available
- ☐ Staff training in data protection and cyber security recorded

Staff sign-off

Name	Role	Signature	Date